

BrightCare Medical Group

HIPAA Security Risk Assessment

Document Information

Field	Value
Organization	BrightCare Medical Group
Document Title	HIPAA Security Risk Assessment
Version	1.0
Assessment Date	January 2024
Classification	Confidential
Conducted By	Information Security Department
Review Frequency	Annually

1. Executive Summary

BrightCare Medical Group conducted a HIPAA Security Risk Assessment to evaluate risks and vulnerabilities affecting the confidentiality, integrity, and availability of Protected Health Information (PHI) and critical healthcare systems.

The purpose of this assessment is to:

- Identify security vulnerabilities
- Evaluate existing safeguards
- Assess operational and cybersecurity risks
- Support HIPAA Security Rule compliance
- Improve organizational security posture

This assessment reviewed administrative, technical, and physical safeguards associated with systems, users, applications, vendors, and operational processes.

2. Assessment Scope

The assessment included the following areas:

- Electronic Health Record (EHR) systems
 - Email systems
 - Cloud platforms
 - Remote access solutions
 - Mobile devices
 - Backup systems
 - Network infrastructure
 - Endpoint devices
 - Third-party vendors
 - Physical security controls
 - Workforce security awareness
 - Access control processes
-

3. Assessment Methodology

The assessment methodology included:

- Documentation review
- Security policy review
- Technical control review
- Interviews with personnel
- Risk identification
- Vulnerability analysis
- Likelihood and impact evaluation
- Risk scoring
- Security recommendations

The assessment was aligned with:

- HIPAA Security Rule
 - NIST Cybersecurity Framework (CSF)
 - NIST SP 800-53
 - Healthcare cybersecurity best practices
-

4. Risk Rating Methodology

Risks were evaluated using the following categories:

Risk Level	Description
Low	Minimal operational or security impact
Medium	Moderate operational or security impact
High	Significant impact requiring prompt remediation
Critical	Severe impact with immediate remediation required

Risk ratings were determined based on:

- Likelihood of occurrence
 - Business impact
 - Exposure of PHI
 - Operational disruption potential
 - Existing safeguards
-

5. Key Findings Summary

The assessment identified several areas requiring improvement including:

- Inconsistent Multi-Factor Authentication (MFA) deployment
- Limited phishing awareness training
- Excessive user access privileges
- Incomplete asset inventory management
- Insufficient vendor risk management procedures
- Limited backup recovery testing
- Weak password practices among users
- Inconsistent endpoint encryption
- Limited centralized logging and monitoring

Several existing security controls were also identified including:

- Antivirus protection
- Basic firewall protections
- Cloud-based email filtering

- VPN-based remote access
 - Existing backup solutions
-

6. Administrative Safeguards Assessment

6.1 Security Awareness & Training

Findings

- Security awareness training exists but is inconsistent.
- Phishing simulation exercises are limited.
- Employees demonstrate varying levels of cybersecurity awareness.

Risk Level

Medium

Recommendations

- Implement mandatory annual security awareness training.
 - Conduct regular phishing simulations.
 - Track completion rates and provide remediation training.
-

6.2 Workforce Access Management

Findings

- Some users maintain excessive access privileges.
- User access reviews are not consistently documented.

Risk Level

High

Recommendations

- Implement Role-Based Access Control (RBAC).
- Conduct quarterly access reviews.
- Enforce least privilege principles.

6.3 Incident Response Readiness

Findings

- Incident response procedures exist but require formal testing.
- Limited tabletop exercises have been conducted.

Risk Level

Medium

Recommendations

- Conduct annual tabletop exercises.
- Improve incident escalation procedures.
- Develop ransomware-specific response playbooks.

7. Technical Safeguards Assessment

7.1 Multi-Factor Authentication (MFA)

Findings

- MFA is enabled for some cloud services but not universally enforced.

Risk Level

High

Recommendations

- Enforce MFA across:
 - Email systems
 - VPN access
 - Administrative accounts
 - Cloud applications
 - Remote access systems

7.2 Endpoint Security

Findings

- Endpoint protection is deployed on most devices.
- Some devices lack encryption or centralized management.

Risk Level

High

Recommendations

- Enforce full disk encryption.
 - Implement centralized endpoint management.
 - Improve endpoint monitoring and patch management.
-

7.3 Logging & Monitoring

Findings

- Logging capabilities are limited across certain systems.
- Security event correlation is minimal.

Risk Level

Medium

Recommendations

- Implement centralized logging and SIEM solutions.
 - Improve security alerting and monitoring.
 - Retain logs according to compliance requirements.
-

7.4 Password Security

Findings

- Weak password practices were observed.
- Password reuse risks exist.

Risk Level

High

Recommendations

- Enforce strong password policies.
 - Implement password managers.
 - Conduct credential hygiene awareness training.
-

8. Physical Safeguards Assessment

8.1 Facility Access Controls

Findings

- Badge access controls exist in some areas.
- Visitor access processes require improvement.

Risk Level

Medium

Recommendations

- Improve visitor management procedures.
 - Expand badge access logging.
 - Restrict access to sensitive areas.
-

8.2 Device Security

Findings

- Some portable devices are not consistently secured.
- Device inventory tracking is incomplete.

Risk Level

Medium

Recommendations

- Improve asset inventory management.
 - Enforce mobile device security controls.
 - Secure storage for portable devices.
-

9. Vendor & Third-Party Risk Assessment

Findings

- Vendor security reviews are inconsistent.
- Limited documentation exists for third-party risk management.

Risk Level

High

Recommendations

- Establish formal vendor risk assessments.
 - Require Business Associate Agreements (BAAs).
 - Review vendor security controls annually.
-

10. Backup & Recovery Assessment

Findings

- Backup solutions are implemented.
- Recovery testing is not consistently documented.
- Offline backup protections are limited.

Risk Level

High

Recommendations

- Conduct annual recovery testing.
- Maintain offline or immutable backups.

- Improve disaster recovery documentation.
-

11. Remote Access Security Assessment

Findings

- VPN access is available for remote users.
- Some remote access sessions lack enhanced monitoring.

Risk Level

Medium

Recommendations

- Expand MFA enforcement.
 - Improve VPN monitoring.
 - Restrict remote access based on device compliance.
-

12. Risk Register Summary

Risk	Risk Level	Recommended Action
Weak Password Practices	High	Enforce password policy and MFA
Phishing Attacks	High	Conduct awareness training and simulations
Excessive User Privileges	High	Implement RBAC and access reviews
Limited Backup Testing	High	Conduct recovery testing
Vendor Security Risks	High	Establish vendor risk management program
Incomplete Logging	Medium	Implement centralized logging
Mobile Device Risks	Medium	Improve MDM and encryption
Physical Access Weaknesses	Medium	Enhance badge and visitor controls

13. Overall Risk Summary

Risk Category	Overall Risk Level
Administrative Safeguards	Medium
Technical Safeguards	High
Physical Safeguards	Medium
Vendor Risk Management	High
Backup & Recovery	High
Security Awareness	Medium

Overall Organizational Risk Level: **High**

14. Recommended Remediation Priorities

Immediate Priorities

- Enforce Multi-Factor Authentication (MFA)
 - Improve password security controls
 - Conduct phishing awareness training
 - Review privileged access permissions
 - Improve backup protections
-

Short-Term Priorities

- Implement centralized logging/SIEM
 - Conduct tabletop exercises
 - Expand endpoint encryption
 - Improve vendor risk assessments
-

Long-Term Priorities

- Mature cybersecurity governance program
- Expand Zero Trust security architecture
- Improve security automation capabilities

- Enhance business continuity planning

15. Conclusion

BrightCare Medical Group has implemented several foundational security controls; however, additional improvements are necessary to strengthen protection of PHI and improve resilience against modern cybersecurity threats.

This assessment identified multiple opportunities to enhance administrative, technical, and physical safeguards aligned with HIPAA Security Rule requirements and healthcare cybersecurity best practices.

Continued investment in cybersecurity governance, workforce awareness, access management, and monitoring capabilities is strongly recommended.

16. Approval

Name	Title	Signature	Date
	Chief Information Officer		
	Information Security Officer		

Revision History

Version	Date	Description	Author
1.0	January 2024	Initial Release	Information Security Department